

Referensi Infrastruktur Server Produksi

PQC PDF Sign

Tanggal penyusunan: 14 September 2026

Status dokumen: rancangan acuan pengadaan dan konfigurasi server produksi.

Ringkasan Produksi

PQC PDF Sign melakukan penandatanganan PDF pada perangkat pengguna. Server produksi menerima PDF yang telah ditandatangani, memverifikasi tanda tangan terhadap Root CA, menyimpan dokumen dan metadata, menyediakan halaman verifikasi publik, serta mendistribusikan pembaruan aplikasi.

Seluruh akses pengguna wajib melalui HTTPS. Port aplikasi dan database hanya tersedia pada jaringan internal. Acuan kapasitas penyimpanan produksi dalam dokumen ini adalah 1 TB.

1. Arsitektur Produksi

Alur utama layanan:

Pengguna Windows/Android -> HTTPS 443 -> Reverse Proxy -> API 8099
Pengunjung QR -> HTTPS 443 -> Reverse Proxy -> Verifier 8098
API -> TCP 5432 -> PostgreSQL
API -> Storage 1 TB untuk PDF dan upload sementara

Komponen produksi:

- Reverse proxy Caddy sebagai satu-satunya layanan aplikasi yang terekspos ke internet.
- Receiver API untuk autentikasi, enrolment, upload, verifikasi, admin, dan update.
- Verification-only service untuk halaman verifikasi publik dan QR.
- PostgreSQL untuk akun, sertifikat, metadata tanda tangan, dan audit.
- Filesystem atau object storage untuk PDF dan upload sementara.
- Sistem backup terpisah dari storage utama.

2. Inventaris Port Produksi

Port | Transport | Akses | Fungsi

443 | TCP | Publik | HTTPS utama melalui HTTP/1.1 atau HTTP/2
443 | UDP | Publik, opsional | HTTPS melalui HTTP/3 dan QUIC
80 | TCP | Publik | Redirect permanen dari HTTP ke HTTPS
22 | TCP | IP admin/VPN | Administrasi server melalui SSH
8099 | TCP | Internal | Receiver API, autentikasi, admin, upload, dan update
8098 | TCP | Internal | Verification-only service dan halaman QR
5432 | TCP | Internal database | PostgreSQL; hanya dapat diakses oleh API
53 | UDP/TCP | Keluar | Resolusi DNS ke resolver yang ditentukan

Aturan firewall produksi:

- Izinkan TCP 80 dan TCP 443 dari internet.
- Izinkan UDP 443 bila HTTP/3 digunakan.
- Izinkan TCP 22 hanya dari VPN atau alamat IP administrator.
- Jangan publikasikan port 8098, 8099, dan 5432 ke internet.
- Batasi koneksi keluar sesuai kebutuhan DNS, backup, pembaruan sistem, dan penerbit sertifikat TLS.

3. Protokol Komunikasi Produksi

Jalur | Protokol | Keamanan

Klien ke reverse proxy | HTTPS melalui HTTP/1.1, HTTP/2, atau HTTP/3 | TLS
Reverse proxy ke API/verifier | HTTP pada jaringan privat | Tidak dapat diakses publik
API ke PostgreSQL | PostgreSQL wire protocol melalui TCP | Jaringan database terisolasi
Administrator ke server | SSH | Kunci SSH dan pembatasan sumber IP
Server ke backup storage | SFTP, HTTPS, atau protokol penyedia storage | Enkripsi saat transit

HTTP/3 pada UDP 443 bersifat opsional. Fungsinya memperbaiki kinerja HTTPS pada jaringan seluler atau jaringan dengan packet loss. Jika tidak tersedia, klien kembali menggunakan HTTP/2 atau HTTP/1.1 melalui TCP 443. HTTP/3 bukan layanan streaming atau port fitur tersendiri.

TLS wajib digunakan untuk seluruh trafik publik. HTTP port 80 hanya digunakan untuk redirect dan tidak boleh melayani login, API, upload, atau data dokumen.

4. Karakteristik Transfer Data

PQC PDF Sign bukan layanan media streaming dan tidak menggunakan WebSocket, RTSP, RTP, WebRTC, MQTT, atau gRPC streaming.

- File kecil dikirim sebagai body HTTPS biasa.
- Klien dapat mengirim file besar dalam chunk agar upload dapat dilanjutkan.
- Endpoint resumable upload menggunakan metode POST, PATCH, dan GET.
- Server menulis upload ke storage sambil menghitung SHA-512.
- Proses stamp dan verifikasi PDF memproses dokumen secara utuh di memori.

Istilah yang tepat adalah HTTPS file transfer dengan chunked/resumable upload. Upload sementara harus memiliki masa kedaluwarsa dan dibersihkan otomatis.

Batas produksi yang disarankan:

Operasi | Batas dokumen

Upload maksimum | 64 MB
Pembuatan stamp server | 64 MB
Verifikasi ketat otomatis | 64 MB
Chunk upload klien | 2 MB per chunk

Batas 64 MB mengikuti baseline stack produksi dan menjaga penggunaan RAM tetap terkendali. Perubahan batas harus disertai pengujian beban karena library PDF memproses seluruh dokumen di memori.

5. Kebutuhan Bandwidth Produksi

Trafik terbesar berasal dari upload PDF, download PDF, dan unduhan aplikasi. Login, QR, sertifikat, metadata, serta audit relatif kecil.

Per transaksi dokumen:

- Metadata, login, reservasi, dan sertifikat: sekitar 50-500 KB.
- Upload PDF: sebesar ukuran dokumen.
- Download PDF: sebesar ukuran dokumen.
- Overhead HTTPS/HTTP: sekitar 2-10 persen.

Ukuran PDF | Upload selesai 1 menit | Upload selesai 5 menit

10 MB | sekitar 1,4 Mbps | sekitar 0,3 Mbps
25 MB | sekitar 3,5 Mbps | sekitar 0,7 Mbps
50 MB | sekitar 7 Mbps | sekitar 1,4 Mbps
64 MB | sekitar 9 Mbps | sekitar 1,8 Mbps

Rekomendasi koneksi produksi:

- Minimum 100 Mbps simetris dengan koneksi stabil.
- Disarankan 500 Mbps simetris untuk banyak pengguna dan upload paralel.

- Skala tinggi menggunakan 1 Gbps simetris dengan pemantauan throughput.
- Sediakan kuota transfer bulanan minimal 1 TB dan evaluasi dari penggunaan nyata.

Contoh trafik: 10.000 dokumen per bulan dengan rata-rata 10 MB menghasilkan sekitar 100 GB upload. Jika seluruh dokumen juga diunduh satu kali, trafik menjadi sekitar 200 GB ditambah overhead, update aplikasi, backup, dan akses web.

6. Rencana Domain dan Subdomain Produksi

Gunakan domain resmi yang singkat dan dimiliki organisasi. Contoh rancangan menggunakan pqsign.id; nama harus diperiksa ketersediaan dan kepemilikannya sebelum pengadaan.

Domain atau subdomain | Fungsi produksi

verify.pqsign.id | Verifikasi publik dan tujuan permanen QR PDF
 api.pqsign.id | API aplikasi Windows dan Android
 admin.pqsign.id | Portal administrasi dengan akses terbatas
 download.pqsign.id | APK, EXE, dan manifest pembaruan aplikasi
 pki.pqsign.id | Root CA, certificate chain, dan CRL publik
 status.pqsign.id | Informasi kesehatan dan gangguan layanan
 docs.pqsign.id | Dokumentasi pengguna dan prosedur operasional

Ketentuan domain produksi:

1. Seluruh subdomain menggunakan HTTPS port 443 dan TLS yang valid.
2. admin.pqsign.id hanya dapat diakses melalui VPN atau allowlist IP.
3. api.pqsign.id menggunakan rate limiting, audit log, dan batas ukuran request.
4. verify.pqsign.id dipertahankan jangka panjang karena URL tertanam dalam PDF.
5. download.pqsign.id dapat diarahkan ke CDN atau object storage di masa depan.
6. pki.pqsign.id harus stabil agar URL CRL dan certificate chain tidak berubah.
7. DNS dikelola pada akun organisasi dengan MFA dan pencatatan perubahan.

Tahap implementasi domain:

1. Daftarkan domain atas nama organisasi.
2. Buat record DNS menuju reverse proxy produksi.
3. Aktifkan TLS dan perpanjangan sertifikat otomatis.
4. Konfigurasi public base URL ke https://verify.pqsign.id.
5. Konfigurasi aplikasi ke https://api.pqsign.id.
6. Konfigurasi updater ke https://download.pqsign.id.
7. Uji login, upload, download, QR, verifikasi, admin, PKI, dan update.
8. Pertahankan redirect alamat lama selama masa migrasi klien dan QR.

QR yang telah tertanam di dalam PDF tidak boleh diedit karena perubahan PDF dapat merusak tanda tangan. Domain verifikasi harus dianggap sebagai alamat permanen.

7. Spesifikasi Storage Produksi 1 TB

Kapasitas storage utama yang digunakan sebagai acuan adalah 1 TB SSD/NVMe. Untuk perencanaan aman, jangan menggunakan seluruh kapasitas secara operasional. Pertahankan minimal 20 persen ruang kosong.

Alokasi yang disarankan:

Kebutuhan | Alokasi

PDF bertanda tangan | 700 GB
 PostgreSQL dan metadata | 80 GB
 Upload sementara/resumable | 60 GB
 Log aplikasi, proxy, dan audit | 40 GB
 APK, EXE, dan riwayat update | 20 GB
 Cadangan ruang operasional | 100 GB
 Total | 1.000 GB

Estimasi jumlah dokumen pada alokasi PDF 700 GB:

Rata-rata ukuran PDF | Perkiraan kapasitas dokumen

5 MB | sekitar 140.000 dokumen
10 MB | sekitar 70.000 dokumen
25 MB | sekitar 28.000 dokumen
50 MB | sekitar 14.000 dokumen

Angka tersebut adalah estimasi kasar sebelum memperhitungkan filesystem overhead dan variasi ukuran file.

Ketentuan storage:

- Gunakan SSD atau NVMe, bukan storage sementara dari instance.
- Pisahkan objek PDF dari database secara logis melalui volume atau filesystem berbeda.
- Aktifkan monitoring penggunaan disk dengan peringatan pada 70, 80, dan 90 persen.
- Hapus upload sementara yang kedaluwarsa secara otomatis.
- Terapkan kebijakan retensi dokumen sesuai kebutuhan hukum dan organisasi.
- Jangan menyimpan private key Root CA pada server aplikasi.
- Enkripsi storage atau volume bila tersedia dari penyedia infrastruktur.

8. Backup dan Pemulihan

Kapasitas backup tidak termasuk dalam storage utama 1 TB dan harus disediakan terpisah. Backup pada disk yang sama tidak melindungi dari kerusakan disk atau kehilangan server.

Rekomendasi minimum:

- Kapasitas backup terpisah minimal 1 TB; disarankan 2 TB untuk beberapa versi.
- Backup PostgreSQL harian.
- Backup objek PDF secara incremental setiap hari.
- Backup data Intermediate CA, CRL, dan ledger setelah perubahan.
- Retensi harian 7 hari, mingguan 4 minggu, dan bulanan sesuai kebijakan.
- Enkripsi backup saat transit dan saat tersimpan.
- Simpan sekurangnya satu salinan di lokasi atau penyedia berbeda.
- Lakukan uji restore berkala dan catat waktu pemulihan aktual.

9. Spesifikasi Server Referensi

Komponen | Spesifikasi produksi yang disarankan

CPU | Minimum 4 vCPU; disarankan 8 vCPU
RAM | Minimum 8 GB; disarankan 16 GB
Storage utama | 1 TB SSD/NVMe
Storage backup | Terpisah, minimum 1 TB; disarankan 2 TB
Jaringan | Minimum 100 Mbps; disarankan 500 Mbps simetris
Sistem operasi | Linux LTS 64-bit yang masih didukung
Container runtime | Docker Engine dan Docker Compose
Public IP | Satu IPv4 statis; IPv6 opsional
TLS | Sertifikat publik dengan perpanjangan otomatis
Monitoring | CPU, RAM, disk, latency, error rate, dan masa berlaku TLS

RAM 16 GB disarankan karena verifikasi dan stamping PDF dapat menggunakan beberapa kali ukuran dokumen dalam memori. Pembatasan resource container tetap harus diterapkan agar satu proses tidak menghabiskan seluruh resource server.

10. Kontrol Keamanan Produksi

- Terapkan MFA untuk akun administrator.
- Gunakan password dan secret unik; jangan gunakan nilai default pengembangan.

- Gunakan kunci SSH dan nonaktifkan login SSH berbasis password bila memungkinkan.
- Batasi admin melalui VPN atau allowlist IP.
- Terapkan rate limiting pada login, verifikasi, dan upload.
- Jalankan API dengan user non-root dan pembatasan CPU, RAM, serta process ID.
- Pisahkan jaringan reverse proxy, API, dan database.
- Jangan publikasikan PostgreSQL atau listener internal.
- Simpan secret di secret manager atau Docker secrets.
- Aktifkan log audit dan rotasi log.
- Terapkan patch keamanan sistem operasi dan container secara berkala.
- Pantau sertifikat TLS, backup terakhir, kapasitas disk, dan error aplikasi.

Kesimpulan

Referensi produksi menggunakan satu pintu publik HTTPS port 443, API dan verifier pada jaringan internal, PostgreSQL yang terisolasi, storage utama 1 TB SSD/NVMe, serta backup terpisah. Konfigurasi awal yang disarankan adalah 8 vCPU, RAM 16 GB, koneksi 500 Mbps simetris, dan backup 2 TB. Domain layanan dipisahkan berdasarkan fungsi agar keamanan, operasional, dan pengembangan kapasitas lebih mudah dikelola.